

RBAC Permission Requirements

Questions and information needed from the SyteLine team so the chatbot follows every user's SyteLine permissions

Item	Detail
Document version	1.0 — for review
Date	25 September 2026
Prepared by	Chatbot development team
Prepared for	SyteLine technical / security administration team
Environment	SyteLine WebClient, configuration AIDEMO (TEST configuration requested)
Related document	SyteLine_Chatbot_Integration_Requirements.docx (embedding, login, screen context)
Action requested	Fill the Answer column (section 4), the Provided column (section 5) and the test-user matrix (section 6)

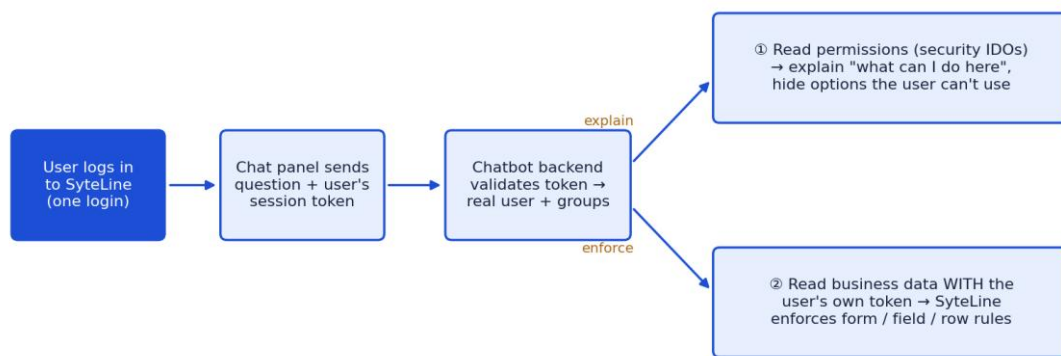
1. Purpose

The chatbot answers Prospect-to-Cash questions inside SyteLine. Before it can show live data or tell a user what they can do on a screen, it must follow that user's SyteLine role-based access control (RBAC) exactly: forms, IDOs, fields, records, sites and business-rule permissions. This document lists what we need to know and receive from the SyteLine team to do that correctly.

Main rule: SyteLine stays in charge of security

The chatbot does not keep its own copy of permissions and never uses a super-user account to read business data. It reads each user's permissions from SyteLine only to explain them and hide options the user cannot use, and it reads data with the user's own session so SyteLine enforces every rule. The chatbot can never give more access than SyteLine does.

2. How the chatbot will use permissions



The chatbot never grants more access than SyteLine: permissions are read, not copied, and every data call runs as the user.

Use	Example	Source
Explain the user's access	"You can view and edit Customer Orders, but releasing a credit hold needs a Credit Manager."	Security IDOs (section 4-B)
Hide what the user can't use	Don't suggest opening a form the user has no access to	Form / IDO authorizations
Protect data	Never show a hidden field, another site's record or another salesperson's customer	SyteLine enforcement with the user's token (4-C, 4-D)
Refuse safely	"You don't have access to invoices. Please contact your administrator."	Effective permissions

3. What is already built

The permission logic is built and running against mock data, behind one adapter that your answers will replace — no other part of the chatbot changes.

Piece	Today (mock)	Will be replaced by
User identity	Test users chosen in a panel (SALES_REP, AR_CLERK, NO_ACCESS)	User from the validated SyteLine session
Permission data	Fixed table per group	Users, groups and authorizations read from SyteLine
Permission checks	Base assistant access + per-feature checks, Redis cache	Same checks, real data (cache time per E1)
Data access	Knowledge base only; live data not connected	IDO calls with the user's own token

4. Questions for the SyteLine team

Priority: Blocker = integration cannot start without it; Needed = required before go-live; Later = can follow. Blocker rows are shaded. Please write answers in the last column (or attach documents and note the name).

A. Security model — how permissions work in your SyteLine

ID	Question	Why we need it	Priority	Answer (SyteLine team)
A1	Is access granted through authorization groups only, or also directly to individual users? If both exist for the same object, which one wins?	To calculate each user's effective permission correctly.	Blocker	
A2	When a user belongs to several groups, are permissions combined (any group allows = allowed), or does a deny in one group win?	Same object can be allowed by one group and denied by another.	Blocker	
A3	Which privileges exist and on which object types? (e.g. Read, Insert, Update, Delete, Execute, Edit on forms, IDOs, IDO methods, properties/fields, form components)	Defines what "can I do this?" means for each object.	Needed	
A4	How do Super User / administrator roles work, and exactly what do they bypass?	Super users must be handled explicitly, never guessed.	Needed	
A5	Can license modules remove access to a form even when the group allows it? How do we read a user's licensed modules?	Otherwise the chatbot may offer forms the user cannot open.	Needed	

B. Reading permissions through the API

ID	Question	Why we need it	Priority	Answer (SyteLine team)
B1	Which IDOs / APIs return the logged-in user, their groups and their object authorizations? (e.g. the IDOs behind the Users, Groups and Object Authorizations forms, such as MGCore.UserNames / MGCore.UserGroupMaps — please confirm exact names)	The core data the permission resolver reads.	Blocker	
B2	Can a normal user read their own permissions, or do we need a read-only service account for security metadata? If a service account, which account and exactly what access?	Decides how the backend is allowed to read security data.	Needed	
B3	Is there one call that returns effective permissions ("what can user X do on form Y"), or must we combine user and group records ourselves?	A SyteLine-computed answer is safer than our own calculation.	Needed	
B4	How do we map each form to its IDO and each field to its IDO property (e.g. Customer Orders → SLCos)?	Links screen permissions to the data behind them.	Needed	
B5	Please share a sample API response for one test user (users, groups, authorizations).	Lets us build and test the adapter before live access.	Needed	

C. Field-level and record-level security

ID	Question	Why we need it	Priority	Answer (SyteLine team)
C1	Can individual fields be hidden or read-only for some users (e.g. cost, margin, credit limit)? Where is it configured and how do we read it?	The chatbot must never show or explain hidden fields.	Blocker	
C2	Are users limited to certain records — by site, warehouse, salesperson, territory, customer? How is it enforced (IDO filters, custom code, site access)?	The chatbot must never reveal other people's records.	Blocker	
C3	Which sites / entities can each user access, and how do we get the site they are currently working in?	Answers and data must match the user's site.	Needed	
C4	Is any data masking used for sensitive fields?	Masked values must stay masked in answers.	Later	

D. Enforcement

ID	Question	Why we need it	Priority	Answer (SyteLine team)
D1	If our backend calls IDO REST with the logged-in user's own token, does SyteLine enforce form, IDO, field and row security automatically?	Our preferred design: SyteLine enforces, the chatbot explains.	Blocker	
D2	Are any checks done only in the WebClient UI and not in the API/IDO layer?	Those checks would not protect API calls; we must add them.	Needed	
D3	Which business-rule permissions exist outside RBAC (e.g. who may release a credit hold, approve discounts, override prices)? Where are they stored?	To answer "can I do X?" correctly.	Needed	
D4	Is the chatbot proof of concept strictly read-only? Which write operations (if any) may be allowed later, and with which approvals?	Scope of future actions.	Needed	

E. Changes, caching and audit

ID	Question	Why we need it	Priority	Answer (SyteLine team)
E1	How quickly must a permission change take effect in the chatbot? We plan a 5-minute cache — acceptable?	Sets the cache time.	Needed	
E2	Can we be notified when permissions change, or should we re-read them at every login/session?	Avoids serving stale permissions.	Later	
E3	What must we log about permission checks and denials, and how long must logs be kept?	Compliance and audit.	Needed	
E4	Should help documents / knowledge articles also be limited by module or form access?	Filter help answers per user.	Later	

F. Testing

ID	Question	Why we need it	Priority	Answer (SyteLine team)
F1	Can we get test users for each role (see the matrix in section 6) in a TEST configuration before AIDEMO?	Prove permissions work before go-live.	Blocker	
F2	Can you export the authorizations of each test group (forms, IDOs, privileges)?	To compare the chatbot's answers with the real settings.	Needed	

5. Items to provide — checklist

Item	Used for	Priority	Provided? (Y/N)	Notes / file name
Security IDO / API names + sample responses	Read users, groups, authorizations	Must have		
Rules document: group vs user, several groups, deny, Super User, licenses	Calculate effective permissions correctly	Must have		
Form → IDO → property mapping for Prospect-to-Cash forms	Link screen permissions to data	Must have		
Field-level and record-level security rules	Never show hidden fields or others' records	Must have		
Business-rule permissions list (credit release, approvals, price override)	Answer "can I do X?" correctly	Must have		
Read-only service account (if needed) + API base URL + auth method	Call the security IDOs	Must have		
Test users per role + TEST configuration	Prove it works before go-live	Must have		
Export of the test groups' authorizations	Check expected vs actual	Needed		
Audit / retention policy for permission logs	Compliance	Needed		

6. Test users — please fill

One test user per role in the TEST configuration. Write the privileges using R = Read, I = Insert, U = Update, D = Delete, X = Execute, — = no access. Add rows for any other role you use.

Role	SyteLine user ID	Groups	Sites	Customer Orders	Estimates / Quotes	Customers	Credit hold release	Invoices	Payments	Hidden fields / row limits
Sales Representative										
Customer Service										
Credit Manager										
AR Clerk										
Read-only / Viewer										
No access										

7. Next steps

#	Action	Owner
1	Answer the Blocker questions: A1, A2, B1, C1, C2, D1, F1	SyteLine team
2	Provide the checklist items (section 5) and test users (section 6)	SyteLine team
3	Build the real permission adapter replacing the mock data	Chatbot team
4	Add "what can I do on this form?" answers from real permissions	Chatbot team
5	Joint test with every test user; compare with the authorization export	Both teams
6	Security review and sign-off before AIDEMO rollout	Both teams

8. Contacts and sign-off

Role	Name	Email / phone	Date
SyteLine security administrator			
SyteLine technical contact			
Chatbot team lead			
Business owner (Prospect-to-Cash)			